

Zero Trust Gap Analysis — Instasafe ZTAA QA Coverage

Well-Tested Tenets

Tenet 3 (Per-session access) and Tenet 6 (Dynamic authentication enforcement) have the strongest test coverage across all labs. Tenet 6 is covered by 8 test cases in Lab III.2 including TOTP expiry, OTP brute force blocking, SQL injection prevention, session timeout, and backup code validation. Additionally, Lab III.8 security testing confirmed serious authentication vulnerabilities including a password hash exposed in JWT tokens (Critical, CVSS 9.1) which directly validates the importance of Tenet 6 testing. Tenet 3 is validated through session timeout tests, logout automation in Lab III.5, and token revocation testing in Lab III.8.

Under-Tested Tenets

Tenet 4 (Dynamic policy-based access) is currently untested. While Instasafe has a policy engine, no existing test case validates that access is dynamically adjusted when a policy changes mid-session. This is a critical gap because real-world ZTNA depends on real-time policy enforcement — a user whose access policy is revoked should lose access immediately without needing to log out.

Tenet 5 (Device integrity monitoring) has minimal coverage — only TC-AS-002 tests a suspended device scenario, but continuous posture monitoring (checking device health during an active session) is not tested. A device that passes the initial posture check but becomes compromised mid-session would not be detected.

Tenet 7 (Continuous monitoring and data collection) has zero test coverage. No lab validates that audit logs are generated correctly, that access attempt failures are logged, or that security events trigger alerts.

Risk of Gaps

The most critical gap is Tenet 5 — an undetected compromised device with valid credentials could maintain full access indefinitely. Combined with the JWT password hash exposure found in Lab III.8, the risk to the authentication and session layer is significant.

Recommended New Test

TC-ZT-004: Configure a device posture policy requiring OS patch level. Mark a test device as non-compliant mid-session. Expected: active session terminated immediately. Objective: validate Tenet 5 continuous posture enforcement — the most critical untested Zero Trust behaviour.